

EasyPark

Post-Code-Review Fixes Report

Generated: June 27, 2026

Repository: Issa-developer/EasyPark

1. Introduction

This document summarizes the bugs, security vulnerabilities, and logic issues identified during a full codebase review of the EasyPark Laravel application, along with the fixes that were applied. All fixes were committed and pushed to the main branch on GitHub.

2. Critical Bug Fixes

2.1 Duplicate Coordinate Migration Removed

Two migrations both attempted to add latitude and longitude columns to the parking_lots table. The duplicate untracked migration was removed so php artisan migrate runs cleanly.

2.2 Missing security.search Method

Routes in routes/web.php and routes/api.php referenced Security\SessionController::search, but the method did not exist. The broken route was removed from both files.

2.3 Client Routes Pointed to Wrong Controller

The /client/history, /client/vehicles, and /client/payments routes all pointed to Client\DashboardController::index, which caused the dashboard view to render for all three pages. They now route to their dedicated controllers:

- /client/history -> Client\HistoryController::index (new controller)
- /client/vehicles -> Client\VehicleController::index
- /client/payments -> Client\PaymentController::index

2.4 History and Payments Views Used Wrong Layout

Both views extended client.layouts.app, which does not exist. They were updated to extend the correct client.layout file.

2.5 Profile Update Read Wrong Field

The profile edit form submits full_name, but Client\ProfileController::update assigned \$request->name. The controller now uses \$request->full_name so name updates persist.

2.6 Vehicles View Used Wrong Column

The vehicles list displayed \$vehicle->plate_number, but the database column is license_plate. The view now shows the correct column.

2.7 Welcome Page Login Form Posted to Wrong Route

resources/views/welcome.blade.php posted the login form to route("login"), which is a GET route. It was changed to route("login.post"), the correct POST endpoint.

2.8 Default Feature Test Failed

The default ExampleTest asserted that GET / returns HTTP 200, but the root URL redirects guests to login (302). The test was updated to assertRedirect(route("login")).

3. Security and Logic Improvements

3.1 CSRF Protection Re-enabled

CSRF token validation was disabled for login, logout, admin/*, security/*, and client/*. All POST forms already included @csrf directives, so the exceptions were removed and CSRF protection is now enforced across all routes.

3.2 Client Dashboard Scoped to Authenticated User

The client dashboard previously showed global session statistics: total sessions, total spent, active session, and recent sessions were not filtered by user_id. All queries now include where("user_id", \$user->id), ensuring users only see their own parking data.

3.3 Sessions Linked to Registered Vehicles/Users

When security logs a vehicle entry, the system now searches the vehicles table by license plate. If a matching vehicle is found, the parking session is created with user_id and vehicle_id populated. This allows client history and billing to be tied to the correct account.

3.4 Login Rate Limiting

A login rate limiter was registered in AppServiceProvider and applied to POST /login. It allows 5 login attempts per minute per IP address, helping mitigate brute-force attacks.

3.5 Password Strength Requirements

Registration and security-guard creation previously required only 6 characters. Both now use Laravel\Validation\Rules\Password requiring at least 8 characters with both letters and numbers.

4. Testing and Verification

After each fix, the following checks were run:

- php artisan test -> 2 passed (Unit ExampleTest + Feature ExampleTest)
- php artisan migrate:status -> clean, no duplicate migration errors

In addition, php artisan db:seed was executed because the local database was empty, which was the root cause of the "Invalid Credentials" login error.

5. Remaining Recommendations

The following improvements were identified but not yet implemented:

- Add atomic spot allocation (database-level locking) to prevent race conditions when two guards assign the same spot.
- Keep parking_lots.total_spots in sync with the actual number of parking_spots rows.
- Remove dead code: unused Laravel UI auth views, layouts/app.blade.php, and welcome.blade.php.
- Add comprehensive feature tests for login, registration, role-based access, security entry/exit, and client dashboard.
- Create invoices and payment records when a parking session ends.
- Add authorization gates / policies for admin and security actions.

6. Commit Log

All fixes were pushed to GitHub on the main branch in the following order:

d5726fd Fix client history and payments views extending wrong layout
bdc45e8 Remove broken security.search route referencing missing controller method
b311fe3 Fix client routes: history, vehicles, and payments now use correct controllers
f5e2f18 Fix profile update to use full_name field from form
b5a8d3e Fix vehicles view to use license_plate column
a732514 Fix welcome page login form to post to correct route
abdb279 Fix default feature test to assert root redirect to login
9208f15 Re-enable CSRF protection for all routes
6d20fa9 Scope client dashboard stats and sessions to authenticated user
f2f869b Link security entry sessions to registered vehicle and user by plate
70f6f02 Add rate limiting to login endpoint (5 attempts per minute)
37f764a Strengthen password requirements to min 8 chars with letters and numbers

Note: database/seeder/DatabaseSeeder.php has a pre-existing uncommitted change that was not modified as part of these fixes.